

TP : Exercices d'applications du traitement des caractères à données personnelles

Contents

1) Problématique.....	1
2) Exercices d'applications.....	1
3) Conclusion.....	8

1) Problématique

Nous cherchons à construire notre savoir-faire pour répondre à l'exigence de sécurité du système d'information d'une organisation en prenant en compte toute ses dimensions, pour pouvoir faire cela nous allons effectuer plusieurs exercices d'applications.

2) Exercices d'applications

1) Analyser un PIA

1. Nous allons, pour pouvoir effectuer les autres exercices, installer le logiciel PIA sur notre ordinateur à l'aide de ce lien :

<https://www.cnil.fr/fr/outil-pia-telechargez-et-installez-le-logiciel-de-la-cnil>

Et ensuite nous allons installer le travail réalisé sous forme de fichier .json avec le lien suivant : lienmini.fr/6988-106

Lorsque le logiciel est installé, on importe le projet :



2. Nous voulons évaluer les niveaux de gravité et de vraisemblance des trois cas suivants : Accès illégitime à des données, Modification non désirées de données, Disparition de données.

Les niveaux de gravité et vraisemblance se calcule comme ça :

Niveau de gravité :

1. **Négligeable** : Aucun impact réel, pas de perturbation notable.
2. **Limité** : Impact limité, facilement réversible, faible coût.
3. **Importante** : Conséquences graves : atteinte à l'activité, aux clients, aspects financiers ou juridiques.
4. **Maximale** : Conséquences catastrophiques, irréversibles ou très lourdes (sanctions, réputation détruite, activité bloquée).

Niveau de vraisemblance :

1. **Négligeable** : Ne peut se produire qu'exceptionnellement.
2. **Limité** : Rare, peu probable mais possible.
3. **Importante** : Risque fréquent, se produit régulièrement.
4. **Maximale** : Quasi certain, risque permanent sans mesure de protection.

Commençons par voir quel niveau de gravité et de vraisemblance chacun des cas possèdent :

Accès illégitime à des données :

Niveau de gravité : 5 -> Les coordonnées personnelles des salariés sont hautement sensibles. Un accès non autorisé peut entraîner une atteinte irréversible à la vie privée, certaines menaces incluent une attaque du serveur de bases de données ou une écoute des échanges lors du transfert vers l'hébergement chez OVH.

Niveau de vraisemblance : 4 -> Les causes probables sont des attaques d'acteurs externes ou d'entreprises concurrentes. Ces tentatives sont fréquentes dans tous les secteurs.

Modification non désirée de données :

Niveau de gravité : 4 -> Une modification non souhaitée des données personnelles peut rendre les informations incohérentes avec le profil du poste, fausser les offres de formation ou empêcher des propositions de mutation/promotion. Cela impacte directement la carrière et les droits du salarié.

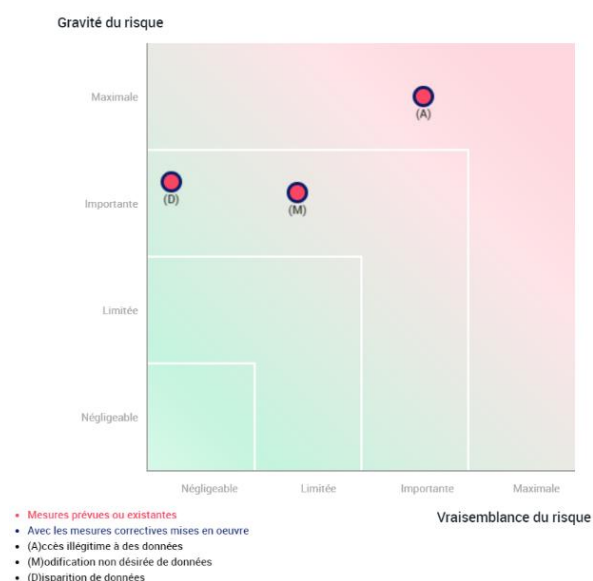
Niveau de vraisemblance : 3 -> Le disque dur de sauvegarde peut être consulté ou modifié, interception lors du transfert vers la base de données, ou encore vol d'identifiants de connexion au poste de travail. Ces scénarios sont plausibles mais moins systématiques qu'une attaque externe directe.

Disparition de données :

Niveau de gravité : 4 (voire 5 sans sauvegarde) -> La perte de données personnelles peut faire disparaître des parties des parcours professionnels des salariés, des obligations de repasser des tests de compétences ou l'exclusion temporaire de formations.

Niveau de vraisemblance : 2 -> Possibles attaques sur les serveurs ou les postes de travail, ou la négligence d'un salarié. Grâce aux mesures existantes le risque de disparition totale reste faible mais réel

3. En commentant et en évaluant les niveaux de gravité et de vraisemblance, et après demande d'évaluation cela va remplir la cartographie des risques :



Comme on peut le voir, l'accès illégitime aux données restent le plus probable et risqué, la disparition reste d'une gravité importante même s'il y a des sauvegardes, mais elle reste moins probable que la modification où l'accès illégitimes des données. Et la modification de données reste plus probable que la disparition mais moins probable que l'accès illégitime.

4. Les mesures correctrices envisageables sont déjà données par

le fichier .json du lien donné, donc nous allons simplement les répertorier ici :

Accès illégitime :

Quelles sont les **mesures initiales**, parmi celles identifiées, qui contribuent à traiter le risque ?

Chiffrement Contrôle des accès logiques

[Cliquez ici pour sélectionner les mesures contribuant à traiter ce risque.](#)

Modification non désirée des données :

Quelles sont les **mesures**, parmi celles identifiées, qui contribuent à traiter le risque ?

Chiffrement Gestion des postes de travail

Contrôle des accès logiques

Disparition des données :

Quelles sont les **mesures**, parmi celles identifiées, qui contribuent à traiter le risque ?

Contrôle des accès logiques Archivage

Gestion des postes de travail

5. Les mesures correctives étaient déjà apparentes sur le schéma d'avant, mais pour préciser à ce qu'elles changent, elles modifient le niveau de gravité et de vraisemblance des cas par rapport aux mesures correctrices qui leurs sont attribuées.

2) Cartographie du traitement des données à caractère personnel

1. La cartographie des traitements des données personnelles consiste à identifier l'emplacement des données personnelles et à recenser tous les traitements faits sur ces données. Elle sert à connaître tout sur les informations stockées au sein d'une entreprise. Elle est réalisée par un recensement de toutes les données possédées par chaque individu de l'entreprise et c'est souvent un DPO (délégué à la protection des données) qui s'en occupe. La cartographie a pour enjeu la mise en conformité avec le RGPD, sans elle il est impossible d'être conforme car elle permet de créer le registre des données personnelles par exemple ou d'autres documents importants. Elle permet aussi de repérer les risques liés au traitement de données ce qui pourra permettre d'éviter les conséquences d'une possible fuite ou mauvaise utilisation. Elle permet donc de pouvoir sécuriser les données à caractère personnel pour qu'il n'y ait aucun souci au sein de l'une entreprise.

2. Le registre des traitements des données à caractère personnel est une étape préalable à la cartographie des traitements car il va être la trace écrite du recensement des données possédées par chaque individu de l'entreprise, c'est grâce à cette trace écrite que la cartographie des traitements va pouvoir se faire.

3) Repérer l'utilisation des données à caractère personnel

1. En saisissant des données personnelles sur le site [castorama.fr](https://www.castorama.fr), les informations vont être partagées avec d'autres entités appartenant au groupe Kingfisher qui comprend plusieurs enseignes comme Brico Dépôt, B&Q, ... Ils cherchent à améliorer les sites web et services numériques du groupe mais aussi à proposer des produits et des services adaptés aux intérêts de l'utilisateur. De plus, Castorama peut partager certaines données avec des tiers qui eux aussi disposent des informations concernant le client, cela leur permet d'identifier les utilisateurs et de leur fournir des renseignements marketing personnalisés. Les données peuvent aussi être transmises à des assureurs dans le cas d'une action judiciaire ou encore utilisées sous forme anonyme pour établir des statistiques. En résumé, les données personnelles saisies sur le site de Castorama peuvent être utilisées à des fins commerciales, ou être utilisés pour faire un partage entre les filiales et partenaires du groupe Kingfisher.

2. On ne peut pas affirmer avec l'extrait que la confidentialité des données personnelles ne soit pas assurée, celui-ci précise que ces données ne sont partagées qu'avec des gens de confiance (partenaire de Kingfisher, assureurs, ...). Mais il se peut tout de même qu'il y ait des failles car l'extrait ne précise rien en rapport avec les mesures de sécurité utilisées ce qui pourrait causer de possibles fuites des données personnelles, il faut donc faire attention à quelles données on partage sur les sites internet.

4) Traitement et risques sur les données à caractère personnel

1. Les différents moyens de collecte, stockage et diffusion à caractère personnel sont :

- Les formulaires en ligne
- Les applications mobiles
- Les enregistrements vocaux ou vidéo
- Les jeux-concours sur les réseaux sociaux
- Les organismes officiels (banques, services d'impôts, ...)

Ces données vont être stockées dans des bases fichiers clients ou dans des bases de données des entreprises, de plus elles peuvent être diffusées par plusieurs moyens comme le courrier électronique, le téléphone, la revente de données et d'autres moyens encore.

2. La vidéo présente plusieurs types de traitements de données :

- La collecte
- L'enregistrement
- La conservation
- La consultation
- La communication
- La suppression

Ces traitements peuvent se réaliser de manière automatisée ou manuelle et servent à des fins de gestion interne et de marketing.

3. Le responsable du traitement doit respecter plusieurs obligations imposées par le RGPD, il doit par exemple être capable de définir la finalité du traitement et de s'assurer que seules les données nécessaires sont collectées. Il doit aussi supprimer les données une fois qu'elles ont été

utilisées, garantir leur sécurité et leur confidentialité et veiller à ce que les sous-traitants respectent également les règles de protection.

4. Les entreprises qui ne respectent pas le RGPD peuvent recevoir de lourdes sanctions financières pouvant aller jusqu'à 4% du chiffre d'affaires mondial ou 20 millions d'euros. Si il y a eu un manque de sécurité l'amende peut atteindre 2% du chiffre d'affaires ou 10 millions d'euros. De plus, il peut aussi y avoir des peines d'emprisonnement allant jusqu'à 5 ans. Et cela peut nuire à la réputation de l'entreprise.

5) Dissociation des notions de sécurité et de sûreté informatique

Scénarios	Sécurité	Sûreté	Justifications
L'ensemble des serveurs est hors-service à cause d'une inondation du local technique		✓	Il s'agit d'un événement naturel (inondation), donc lié à la sûreté (protection contre les accidents).
Les données d'un hôpital sont illisibles à la suite d'une attaque de type ransomware	✓		Le ransomware est une attaque informatique intentionnelle donc elle relève de la sécurité (protection contre les actes malveillants).
L'apparence du site vitrine d'une entreprise est modifiée pendant un week-end par des personnes malveillantes	✓		Modification malveillante du site par des hackers, donc problème de sécurité.
Une surcharge électrique temporaire due à des travaux réalisés dans les bâtiments de la société provoque une panne des routeurs		✓	La panne est due à un incident technique non intentionnel (surcharge), donc liée à la sûreté.

6) Identifier les données à caractère personnel

Données	Caractère personnel	Justifications
Le nom de l'enseigne du magasin Carrefour	X non	Il s'agit d'une information liée à une entreprise et non à une personne identifiable.
L'adresse courriel professionnelle d'un directeur des services informatiques	V oui	Permet d'identifier une personne physique par sa fonction et ses coordonnées professionnelles.
Une photo postée sur un réseau social	V oui	Une photo permet souvent d'identifier une personne physique.
Une vidéo de présentation de son parcours professionnel envoyée à une entreprise dans le cadre d'un recrutement	V oui	La vidéo contient des informations personnelles et permet d'identifier la personne.
Les coordonnées GPS de localisation d'un smartphone	V oui	Les données GPS permettent de suivre et d'identifier la localisation d'une personne.
Le groupe sanguin d'un patient stocké sur le serveur de base de données de son médecin	V oui	Le groupe sanguin est une donnée de santé directement liée à une personne.
Les enregistrements de vidéosurveillance d'un datacenter	V oui	Les enregistrements peuvent permettre d'identifier une personne filmée.
Le numéro d'enregistrement au registre du commerce et des sociétés d'une entreprise	X non	Information liée à une personne morale (entreprise), pas à une personne physique.
Le numéro de sécurité sociale d'un salarié saisi sur sa fiche d'embauche	V oui	Le numéro de sécurité sociale identifie directement une personne physique.

3) Conclusion

En conclusion, ce TP m'a permis de mieux comprendre la gestion et la protection des données à caractère personnel, j'ai pu apprendre grâce aux exercices à identifier les données sensibles, à évaluer les risques et à proposer des mesures de sécurité adaptées à la menace.